

Tài Liệu Thiết Kế Hệ Thống: Merkle Tree Log Integrity

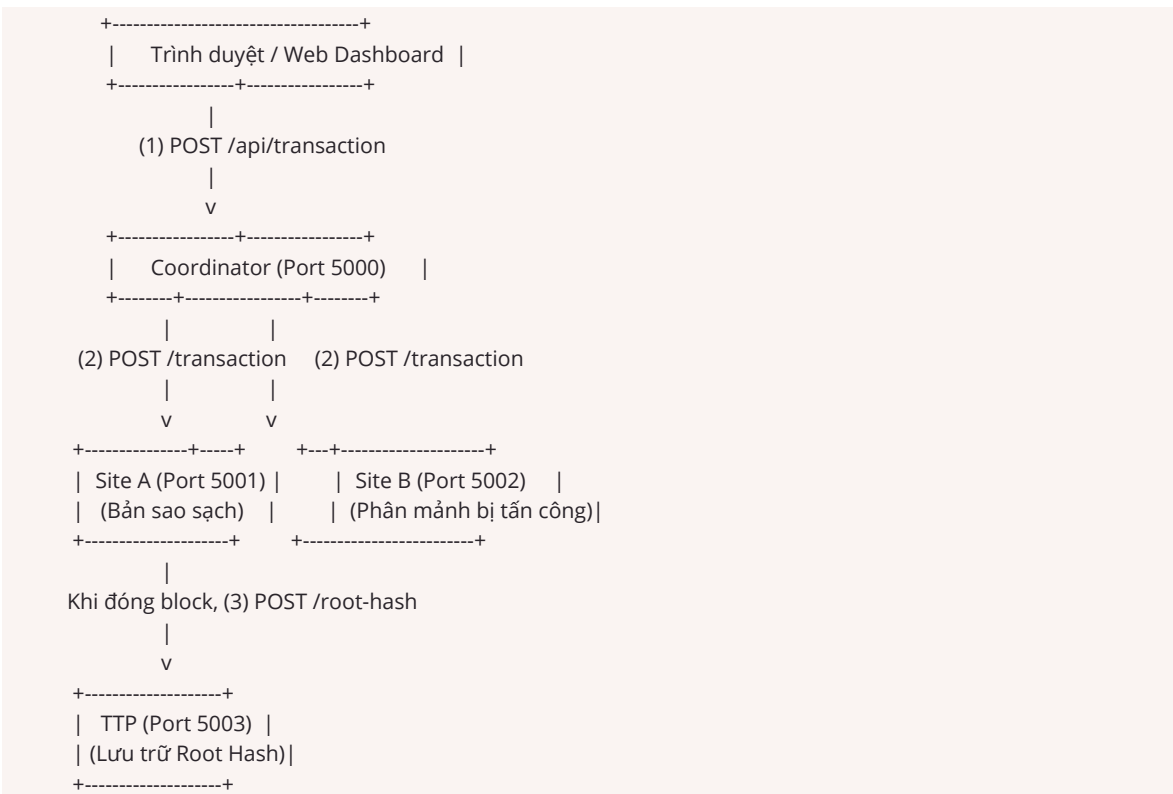
1. Giới thiệu & Định nghĩa bài toán

Nhật ký giao dịch (audit log) trong cơ sở dữ liệu ngân hàng là mục tiêu béo bở của những kẻ tấn công. Trong khi các cơ chế tường lửa, kiểm soát truy cập mạng và phân quyền ở cấp ứng dụng có thể ngăn ngừa hiệu quả các mối đe dọa bên ngoài, chúng hoàn toàn bất lực trước **Tấn công nội bộ (Insider Attacks)** (ví dụ: quản trị viên cơ sở dữ liệu có đặc quyền cao truy cập trực tiếp vào máy chủ CSDL thô dưới đĩa cứng).

Hệ thống này hiện thực hóa cơ chế **Kiểm toán tính toàn vẹn nhật ký phân tán** sử dụng **Cây Merkle (Merkle Tree)** để phát hiện hành vi can thiệp CSDL. Lưu ý rằng hệ thống được thiết kế để **phát hiện và định vị lỗi**, chứ không ngăn chặn vật lý hành vi ghi đè file trên ổ cứng.

2. Thiết kế kiến trúc hệ thống

Hệ thống bao gồm 4 node logic chạy độc lập dưới dạng các Flask microservices giao tiếp qua HTTP/REST APIs:



Các thành phần và Chiến lược phân tán

- Coordinator Node:** Cổng tiếp nhận giao dịch từ máy khách. Thực hiện nhân bản đồng bộ (Write-All) sang cả Site A và Site B, tự động điều phối đóng block để dựng cây băm. **Lưu ý về SPOF:** Coordinator hiện tại là điểm lỗi duy nhất (Single Point of Failure); hướng phát triển trong tương lai là tích hợp giao thức đồng thuận phân tán như **Raft** hoặc **PBFT** để tăng độ sẵn sàng và tin cậy cho Coordinator.
- Site A Node:** Lưu trữ bản sao giao dịch sạch, tin cậy. Node này là bắt buộc để phục vụ điều tra số (Forensics) - làm đối chứng tìm ra giao dịch nào bị can thiệp khi phát hiện sai lệch.
- Site B Node:** Lưu trữ bản sao giao dịch ngân hàng chi nhánh. Đây là đối tượng chịu tấn công vật lý (Rogue DBA SQL tampering) dưới ổ đĩa.

4. **Trusted Third Party (TTP)**: Bên thứ ba tin cậy chỉ lưu trữ phạm vi Block và các Root Hash tương ứng. TTP không lưu thông tin chi tiết giao dịch thô nhằm bảo mật quyền riêng tư của khách hàng, đóng vai trò kiểm toán độc lập cấp Block.

3. Thiết kế mã hóa mật mã & Lưu trữ

A. Lược đồ cơ sở dữ liệu SQLite

Ba tệp cơ sở dữ liệu SQLite độc lập (site_a.db, site_b.db, và ttp.db) mô phỏng các node lưu trữ phân tán:

-- Bảng giao dịch tại Site A & Site B

CREATE TABLE Banking_Transactions (

TransactionID TEXT PRIMARY KEY,

From_Account TEXT NOT NULL,

To_Account TEXT NOT NULL,

Amount REAL NOT NULL,

Timestamp TEXT NOT NULL,

BlockID INTEGER NOT NULL);

-- Bảng lưu trữ mã băm gốc tại TTP

CREATE TABLE Block_Hashes (

BlockID INTEGER PRIMARY KEY,

StartTxID TEXT NOT NULL,

EndTxID TEXT NOT NULL,

RootHash TEXT NOT NULL,

Timestamp TEXT NOT NULL);

B. Quy chuẩn thuật toán Cây Merkle

- **Chuẩn hóa lá (Leaves Serialization)**: Các giao dịch được chuyển thành chuỗi chuẩn hóa trước khi băm:

$S(tx) = \text{TransactionID} | \text{From_Account} | \text{To_Account} | \text{Amount (2 chữ số thập phân)} | \text{Timestamp}$

$$\text{LeafHash} = \text{SHA256}(S(tx))$$

- **Xử lý số lá lẻ**: Nếu một tầng có số lượng nút lẻ, nút cuối cùng sẽ được tự động nhân đôi để ghép cặp cho đủ cấu trúc cây nhị phân cân bằng.
- **Dựng nút cha**: Ghép chuỗi hai nút con rồi thực hiện băm SHA-256:

$$\text{ParentHash} = \text{SHA256}(\text{LeftHash} + \text{RightHash})$$

4. Thiết kế các API Endpoints

Coordinator (Port 5000)

- POST /api/transaction: Tiếp nhận giao dịch mới và nhân bản đồng bộ.
- GET /api/transactions?site=a|b&block_id=id: Lấy danh sách giao dịch từ các site.
- GET /api/merkle-tree/<int:block_id>: Lấy cấu trúc các tầng của cây Merkle phục vụ vẽ biểu đồ trên Web.

- GET /api/audit: Khởi chạy quét kiểm toán và phân tích sai lệch.
- POST /api/seed: Sinh 500 giao dịch mẫu sạch ban đầu.
- POST /api/benchmark: Chạy tiến trình đo đặc hiệu năng hệ thống.

Sites A & B (Port 5001 & 5002)

- POST /transaction: Lưu giao dịch vào database cục bộ.
- GET /transactions?block_id=id: Lấy danh sách giao dịch cục bộ.
- GET /leaf-hashes?block_id=id: Lấy danh sách mã băm nút lá để đối chiếu kiểm toán.
- POST /simulate-attack (Chỉ ở Site B): Thực thi truy cập SQL thô để cập nhật/xóa/chèn giao dịch giả lập tấn công.

TTP (Port 5003)

- POST /root-hash: Đăng ký lưu trữ mã băm gốc cho Block đã đóng.
- GET /root-hashes: Lấy danh sách mã băm gốc của tất cả các block.

5. Quy trình Kiểm toán & Truy vết sai lệch (Audit Flow)

1. **Kiểm tra mã băm gốc:** Bộ kiểm toán lấy danh sách Root Hashes từ TTP. Với mỗi Block NN , hệ thống tính toán Root Hash từ dữ liệu Site B hiện tại và đối chiếu với TTP.
2. **Phát hiện can thiệp:** Nếu $Root_B \neq Root_{TTP}$, Block NN bị đánh dấu là bị can thiệp (TAMPERED).
3. **Điều tra và Truy vết (Forensic Analysis):** Bộ kiểm toán yêu cầu lấy danh sách mã băm nút lá (Leaf Hashes) của Block NN từ Site A (bản sạch) và Site B (bản lỗi), thực hiện so khớp để chỉ điểm:
 - **Modified (Bị sửa đổi):** Cùng TransactionID nhưng giá trị mã băm khác nhau. Hệ thống sẽ truy vấn cả hai database để đối chiếu chỉ ra trường bị thay đổi (ví dụ: số tiền bị sửa đổi).
 - **Deleted (Bị xóa):** TransactionID tồn tại ở Site A nhưng bị biến mất ở Site B.
 - **Injected (Bị chèn không):** TransactionID tồn tại ở Site B nhưng không tồn tại ở Site A.
 - Kết quả phân tích sai lệch chi tiết được in ra màn hình console và kết xuất lên giao diện Web.

6. Xử lý sập Node phân tán (Distributed Node Failure Scenario)

Hệ thống xử lý kịch bản lỗi khi một trong các node cơ sở dữ liệu chi nhánh (ví dụ: Site B) bị sập (offline) dựa trên các nguyên tắc thiết kế phân tán:

1. **Ràng buộc nhất quán tuyệt đối (Consistency over Availability):** Dưới giao thức nhân bản đồng bộ Eager Replication và mô hình ROWA (Read-One/Write-All), mọi giao dịch ghi mới bắt buộc phải thực hiện thành công trên cả hai site bản sao. Khi Site B sập, yêu cầu ghi giao dịch mới gửi đến Coordinator sẽ gặp lỗi kết nối và bị từ chối (trả về mã lỗi HTTP 500). Hệ thống lựa chọn bảo vệ tính nhất quán, ngăn ngừa dữ liệu giữa hai site bị lệch hướng (CAP Theorem trade-off).
2. **Khả năng chịu lỗi đọc (Read Resilience):** Do áp dụng mô hình ROWA, việc đọc dữ liệu chỉ cần truy vấn một site bất kỳ. Nếu Site B bị sập, Coordinator tự động điều phối các truy vấn đọc hướng sang Site A, đảm bảo giao diện Dashboard vẫn hiển thị lịch sử giao dịch sạch bình thường.
3. **Giới hạn kiểm toán:** Quá trình kiểm toán thông qua detector.py yêu cầu kết nối đồng thời đến TTP, Site A và Site B. Nếu một node bị sập, công cụ detector sẽ đưa ra cảnh báo lỗi kết nối và tạm ngưng cho đến khi mạng được khôi phục.